Sprint 3 Trivy Static Review - Seth Martin

Student: Seth Martin | **Project:** Rate My Fries (FRY) | **Sprint:** FRY Sprint 3, October 20-November 3, 2026.

Report date: November 3, 2026. Snapshot verified from live Jira/GitHub; times use America/Chicago. October 20 was CDT (UTC-05:00); November 3 is CST (UTC-06:00).

Tool and completed execution

Actual Trivy 0.76.0 filesystem scan, run locally in the official container with dependency-vulnerability, misconfiguration and secret scanners enabled. The process exited successfully. This PDF is calculated from its JSON output; it is not a deployment-image scan. Tool output and image digest are retained.

Required severity metrics

Severity	Dependency vulnerabilities	Misconfigurations	Secrets	All findings
CRITICAL	0	1	0	1
HIGH	0	0	0	0
MEDIUM	0	1	0	1
LOW	0	1	0	1
UNKNOWN	0	0	0	0
Total	0	3	0	3

There are zero dependency vulnerabilities and zero secrets, but **three configuration findings**. A successful scanner exit indicates completed execution, not a clean assessment. The default scan command does not fail its process merely because a finding exists.

Findings and review recommendations

Rule	Severity	Resource	Finding
AWS-0104	CRITICAL	PrivateSecurityGroup	A security group rule should not allow unrestricted egress to any IP address.
AWS-0123	MEDIUM	infra/private-ec2.template.json:205-313	IAM groups should have MFA enforcement activated.
AWS-0124	LOW	PrivateSecurityGroup	Missing description for security group rule.

- AWS-0104: the security group allows all outbound protocols to 0.0.0.0/0. This is **egress**, not a public inbound website rule. Zero ingress and the app's loopback binding were separately verified during migration. Restrict outgoing protocols/ports to required traffic and evaluate destination restrictions for SSM, package updates and Google endpoints against the low-cost design. Do not claim that allowing HTTPS alone will necessarily clear a destination-based rule.
- AWS-0123: the IAM group permits first-login password changes but does not enforce MFA. Review an enrollment/enforcement plan with both collaborators and test browser-based CLI sign-in and initial enrollment before changing a deny policy. The scanner finding remains open; no account or permission settings were changed here.

- AWS-0124: the outbound rule has no description. Add an auditable description in the source renderer/template through the normal reviewed change workflow.

References: AWS-0104, AWS-0123, AWS-0124. These links are the actual scanner's rule references. No finding was suppressed or converted to a passing check.

Exact scan scope

This is an **analysis-only composite**, not a merged branch or a claim that main contains pending changes. All 42 source files were exported from Git before scanning:

Source	Exact revision
Deployed runtime (pending #7/#9/#10 combination)	d094cd8e52b1dcf413ed1a36209a367abe525262
Catalogue importer/data/tests (#8)	bb9673abc28c0a0060d6292facdc77363a69145b
EC2 template/bootstrap/tools/tests (#11)	d7b7bf5ed9ffa6c6562f91223609e65a0635c1c9

Source-manifest SHA-256: `29b4cfd5a586b98a29a9bab4eb49e6a78b66ca749261122e091b82d64724abf4`. The manifest records the originating revision and SHA-256 for every source file. The snapshot includes Python, JavaScript, HTML/Jinja, CSS, shell, PowerShell, JSON/CloudFormation and the SQL schema. Analyzer support differs by language; including a file does not imply a dedicated analyzer for every format. Source scope expanded from 917 to 1910 Sonar non-comment lines.

Git history, databases, signing keys, Google/API configuration, virtual environments, prior reports, demos and IDE files were excluded. Tests are classified separately from production source. Coverage XML and a resolved Python dependency inventory were generated for the scan. No deployment image or running AWS account was scanned.

Detection limits

Trivy detected two Python dependency targets and one CloudFormation file. The resolved inventory includes test/coverage dependencies used for this analysis. The tool warned that VPC/subnet/collaborator parameter values were not supplied; it still parsed and assessed the template. No names or deployment secrets were inserted to silence that warning. Python site-packages was not mounted, so license detection was skipped while dependency vulnerability detection completed. No operating-system packages, live IAM state, container image or dynamic AWS network behavior are included in the dependency counts.

Trend and reflection

The October 20 same-sprint baseline reported zero dependency vulnerabilities, zero misconfigurations and zero secrets, with no supported infrastructure target detected. Dependency findings remain zero; the current expanded scan now detects three infrastructure findings. This is broader coverage, not evidence that an unchanged prior configuration became unsafe. No Sprint 2 scan exists for a previous-sprint trend.

The main remaining risk is deployment hardening rather than a detected package CVE. Resolve or explicitly review the egress, MFA and audit-description findings before considering FRY-59 fully accepted, then rescan the reviewed source. Keep original raw evidence and distinguish future fixed results from this snapshot. The reporting task did not start the EC2 instance, publish the website or modify AWS configuration.

This static analysis was generated using automated tools during this sprint.

Evidence: trivy.json, trivy.log, trivy-version.txt, trivy-image.txt, requirements-resolved.txt and scan-metadata.json in the accompanying raw evidence.